

TRƯỜNG ĐẠI HỌC VĂN HIẾN

Khoa Công Nghệ Thông Tin

BẢO MẬT IOT TRONG Y TẾ THÔNG MINH

Học phần - Bảo mật trong IoT

Giảng viên - Hồ Nhật Minh

Đề tài - 09

Sinh viên - Lâm Quốc Duy

Mã số sinh viên - 231A010064

Mục Tiêu Của Đề Tài



Vấn Đề Bảo Mật Hiện Hữu



Vòng Đo Nhịp Tim

Máy Chủ Đám Mây

Dashboard

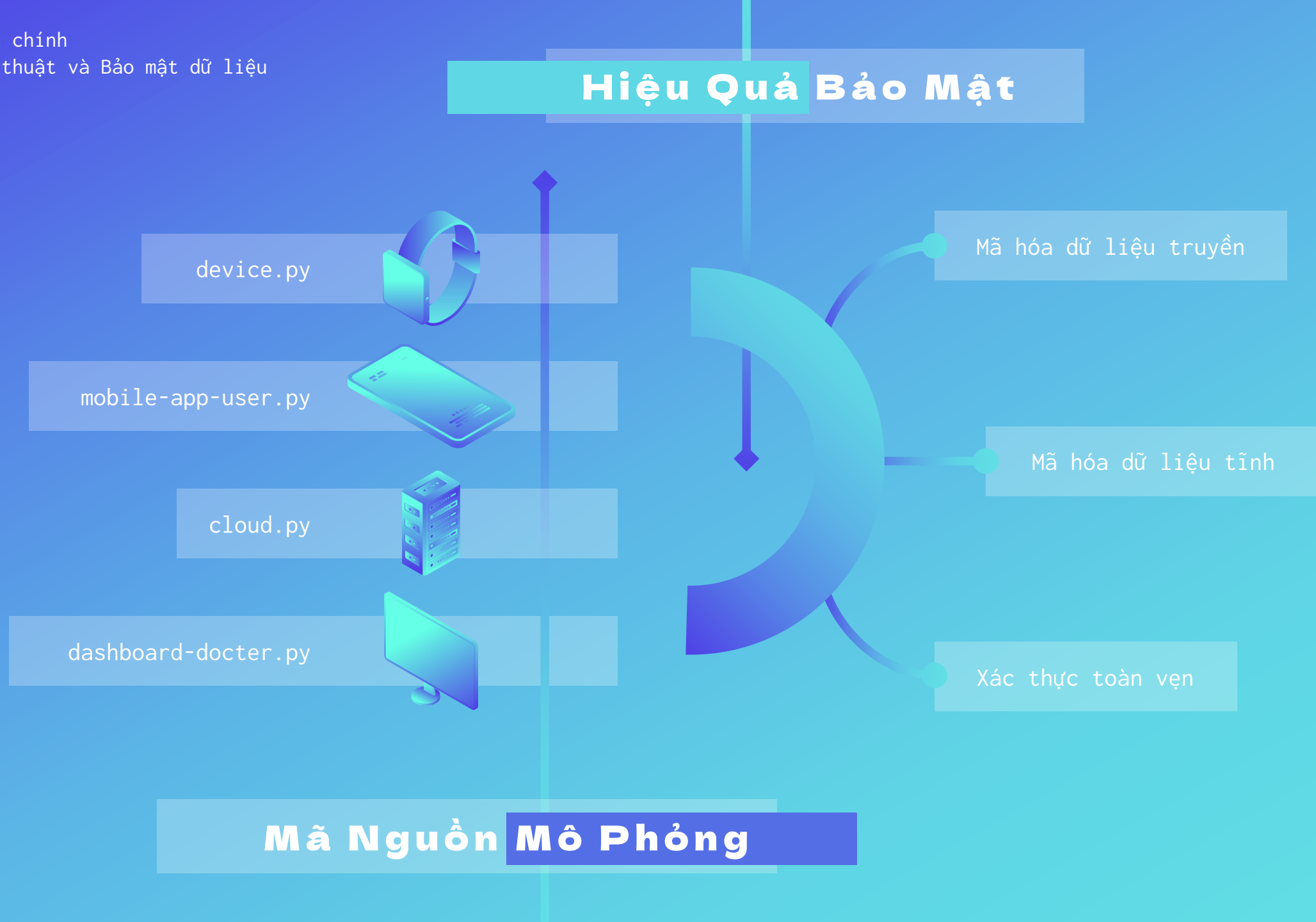
Ứng Dụng Di Động

MQTT/HTTPS (TLS 1.3) + HMAC

HTTPS + JWT + MFA + RBAC/ABAC

BLE SC + AES-CCM





```
{
  "timestamp": "2026-07-17 17:11:19",
  "event_type": "DOCTOR_LOGIN",
  "status": "SUCCESS",
  "details": "Bác sĩ dr_smith đăng nhập thành công",
  "requester_ip": "127.0.0.1"
},
{
  "timestamp": "2026-07-17 17:11:21",
  "event_type": "ACCESS_ATTEMPT",
  "status": "BLOCKED",
  "details": "Cố gắng truy xuất thông tin thiếu Token xác thực",
  "requester_ip": "127.0.0.1"
},

```

STT	Nhóm yêu cầu / Tiêu chí kiểm tra	Thực thể áp dụng	Chuẩn tham chiếu
3.3	Có cơ chế tự động thoát (Automatic Logoff) sau thời gian chờ?	Dashboard	HIPAA 164.312
4	Nhật ký và Giám sát (Audit & Logging)		FDA / HIPAA
4.1	Ghi vết mọi hành vi truy xuất dữ liệu nhạy cảm?	Cloud Server	HIPAA 164.312(b)
4.2	Log ghi nhận đủ: IP, Timestamp, Loại sự kiện, Trạng thái?	Cloud Server	FDA Postmarket
4.3	Tự động cảnh báo khi phát hiện sai chữ ký HMAC?	Cloud Server	ISVS 1.3
5	An toàn thiết bị và Firmware (Hardening)		ISVS V5 / FDA

```
{
  "timestamp": "2026-07-16 14:17:45",
  "event_type": "RECEIVE_DATA",
  "status": "FAILED",
  "details": "Sai khớp chữ ký HMAC bảo mật dữ liệu nhạy cảm",
  "requester_ip": "127.0.0.1"
},
{
  "timestamp": "2026-07-16 14:17:54",
  "event_type": "RECEIVE_DATA",
  "status": "SUCCESS",
  "details": "Lưu thành công nhíp tim bệnh nhân PATIENT-9981",
  "requester_ip": "127.0.0.1"
},

```

Checklist Bảo Mật

Kiểm Soát Truy Cập (RBAC)

Nhật Ký Giám Sát (Audit Log)

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Chỉ số nhịp tim (BPM)	Bệnh nhân	Rất cao	Integrity, Confidentiality	Dữ liệu sinh tồn phục vụ chẩn đoán
Nhân thời gian (Timestamp)	Bệnh nhân	Cao	Integrity, Confidentiality	Xác định thời điểm đo chỉ số
Tọa độ GPS	Bệnh nhân	Cao	Confidentiality	Liên quan đến quyền riêng tư và vị trí thực
Mã bệnh nhân (Patient ID)	Bệnh nhân	Cao	Confidentiality	Thông tin định danh nhạy cảm
Khóa mật mã (AES, HMAC)	Hệ thống	Rất cao	Confidentiality	Tài sản kỹ thuật duy trì hành lang bảo mật
Nhật ký hệ thống (Audit Logs)	Quản trị	Trung bình	Integrity	Phục vụ điều tra và giám sát xâm nhập

Tài sản và dữ liệu cần bảo vệ

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động
T-01	Nhịp tim	Nghe lén	BLE ở chế độ "Just Works" không mã hóa.	Lộ thông tin sức khỏe nhạy cảm.
T-02	Toàn vẹn dữ liệu	Giả mạo	Chặng Internet truyền văn bản rõ, thiếu mã xác thực HMAC.	Sai lệch kết quả chẩn đoán y khoa.
T-03	Quyền truy cập	Truy cập trái phép	Thiếu cơ chế phân quyền RBAC và xác thực JWT.	Kẻ xấu xem lên hồ sơ bệnh nhân khác.
T-04	Dữ liệu tĩnh	Rò rỉ tệp dữ liệu	Lưu trữ trên Cloud dạng plaintext không mã hóa.	Lộ hàng loạt hồ sơ nếu mất file vật lý.
T-05	Dòng dữ liệu	Tấn công phát lại	Hệ thống không kiểm tra tính tươi mới của nhân thời gian.	Kẻ tấn công gửi lại lệnh/ dữ liệu cũ để đánh lừa bác sĩ.

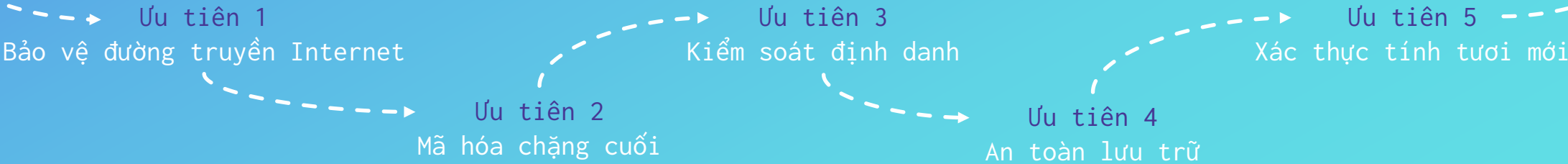
Mối đe dọa và lỗ hổng

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	5	4	20	Nghiêm trọng	Áp dụng AES-CCM cho chặng BLE.	Thấp
R-02	4	5	20	Nghiêm trọng	Tích hợp HMAC-SHA256 bảo vệ nhịp tim & timestamp.	Rất thấp
R-03	3	5	15	Cao	Sử dụng JWT (HS256) để phân quyền bác sĩ.	Trung bình
R-04	2	5	10	Trung bình	Mã hóa lưu trữ tĩnh bằng AES-GCM.	Thấp
R-05	4	4	16	Cao	Hậu kiểm nhân thời gian tại Cloud trước khi lưu trữ.	Thấp

Ma trận rủi ro

Phân Tích Rủi Ro

Biện Pháp Phòng Chống Và Ưu Tiên Xử lý





Hoàn Thành Mục Tiêu Dự Án

Xây dựng thành công hệ thống mô phỏng, thực thi đầy đủ 5 trụ cột bảo mật cốt lõi.

Minh Chứng Hiệu Quả Phòng Thủ

Chặn đứng các hành vi xâm nhập trái phép, khẳng định sự cấp thiết của việc dịch chuyển trạng thái bảo mật.

Giá Trị Và Tính Tuân Thủ

Bước đầu tiên cần được các yêu cầu an toàn kỹ thuật khắc khe theo các chuẩn quốc tế.



Repository Dự Án

<https://github.com/LamQuocDuy/Bao-Mat-IoT-Trong-Y-Te-Thong-Minh>

Tài Liệu Tham Khảo

OWASP ISVS

RFC 2104 & RFC 7519

Mbed TLS Library

Chuẩn HIPAA & Hướng dẫn FDA

NIST SP 800-38D